

AI Agent Security Assessment

Subject agent: sample_agents:devops_crew.py

OVERALL RISK RATING

100

CRITICAL

Posture grade F · Governance verdict DENY

Report reference	AS-20260624-09F9F8
Subject agent	sample_agents:devops_crew.py
Agent identifier	agent://platform-team/sample_agents-devops_crew.py
Framework	crewai
Discovery source	code
Accountable owner	platform-team
Classification	CONFIDENTIAL — internal distribution only
Date of issue	24 June 2026
Report version	1.0
Prepared for	Demo Organization
Prepared by	AgentShadow Automated Assessment Engine
Reviewed / approved by	Governance policy engine · Block high-risk agents (DENY)

Confidentiality notice. This report contains a security assessment of an AI agent and is classified CONFIDENTIAL. It is intended solely for the named recipient and authorized personnel. Findings reflect the agent configuration observed at the time of assessment and should be revalidated after any change.

0 Document Control

Version	Date	Author	Status	Description
1.0	2026-06-24	AgentShadow Platform	Final	Automated assessment generated from discovery + deterministic scoring.

Distribution list: Agent owner (platform-team); Information security team; AI governance & risk committee; Platform engineering lead

Contents

- 1. Executive Summary
- 2. Scope & Methodology
- 3. Risk Assessment & Scoring
- 4. Detailed Findings
- 5. Governance & Policy Compliance
- 6. Remediation Roadmap
- 7. Appendix — Agent Profile & References

1 Executive Summary

AgentShadow assessed the AI agent **sample_agents:devops_crew.py**, built on the **crewai** framework and discovered via **code** discovery. The agent operates at an estimated **medium** autonomy level with **1** tool(s) in scope. Applying its deterministic risk engine, AgentShadow assigned an overall risk score of **100.0 / 100**, placing the agent in the **CRITICAL** risk band, and identified **11** finding(s). The resulting governance verdict is **DENY**.



Findings by severity

Critical	High	Medium	Low	Informational
2	2	1	6	0

Business impact context

At CRITICAL risk (100/100), this agent poses a critical risk to production systems, credentials, and sensitive data. It operates at medium autonomy, so actions may proceed with limited human oversight between discovery cycles. Tools in scope (1): shell_exec. Each capability expands the blast radius of a compromised or misdirected agent. Exposed credentials could enable unauthorized API access and lateral movement. Shell, code execution, or network tools could allow unintended system changes or data exfiltration. Prompt-injection weaknesses could cause the agent to bypass intended guardrails. Governance verdict DENY — block deployment or continued operation until remediated.

2 Scope & Methodology

AgentShadow discovers AI agents from source code and runtime connectors, then scores each agent with a deterministic engine and evaluates it against governance policy. This assessment covers a single agent and its observable configuration; it does not execute the agent or perform dynamic exploitation.

Assessment scope

In scope	Agent 'sample_agents:devops_crew.py' (crewai); discovery location below.
Discovery location	/app/sample_agents/devops_crew.py
Assessment window	24 June 2026 21:24 — 21:55 UTC (assessment snapshot)
Environment	Source repository · static code analysis (/app/sample_agents/devops_crew.py)
Out of scope	Dynamic exploitation, adversarial red-team testing, runtime behavioural fuzzing, underlying cloud infrastructure, and third-party LLM provider security are out of scope unless explicitly contracted separately.

Methodology & reference frameworks

- Findings are produced by static analysis of the agent definition (framework usage, tools/capabilities, system prompt, autonomy signals and secret exposure) and mapped to recognized industry standards:
- **OWASP Top 10 for LLM Applications** — prompt injection, sensitive information disclosure, excessive agency.
 - **MITRE ATLAS** — adversarial tactics and techniques for AI-enabled systems.
 - **NIST AI Risk Management Framework (AI RMF 1.0)** — Govern / Map / Measure / Manage functions.

Risk scores are deterministic: identical agent configurations always yield identical scores, making results reproducible and audit-friendly.

3 Risk Assessment & Scoring

The overall risk score aggregates the severity and weight of each finding, the agent's autonomy level and the blast radius of its tools. The breakdown below shows the factors that drove this agent's rating.

Overall risk score	100.0 / 100
Risk band	CRITICAL
Posture grade	F
Highest finding severity	Critical (5/5)
Total findings	11
Autonomy level	medium
Tools / capabilities in scope	1
Governance verdict	DENY

Interpretation. Scores of 80–100 are CRITICAL and warrant immediate action; 60–79 HIGH; 40–59 MEDIUM; 20–39 LOW; 0–19 MINIMAL. Bands align to the governance enforcement thresholds in Section 5.

4 Detailed Findings

11 finding(s) are detailed below, ordered by severity. Each finding is mapped to an industry standard and includes the supporting evidence and a recommended remediation.

F-01 ab_hardcoded_credential		CRITICAL
Category	secret_exposure	
Severity	Critical (5/5) · detection weight 35	
Mapped standard	OWASP LLM06: Sensitive Information Disclosure · CWE-798	
Evidence	... only, not a real key OPENAI_API_KEY = "sk-demoFAKEkey0000000000000000demo" def run_command(cmd: str) -> str: ...	
Recommendation	Remove hardcoded credentials; load secrets from a managed vault at runtime and rotate any exposed keys.	
Remediation owner	platform-team · target 2026-07-01	

F-02 ab_shell_tool		CRITICAL
Category	dangerous_tool	
Severity	Critical (5/5) · detection weight 35	
Mapped standard	OWASP LLM08: Excessive Agency · MITRE ATLAS AML.T0053	
Evidence	...ardrails (should be flagged) return subprocess.run(cmd, shell=True, capture_output=True, t...	
Recommendation	Restrict or sandbox high blast-radius tools (shell, code execution, outbound network). Require explicit allow-lists and least-privilege scoping.	
Remediation owner	platform-team · target 2026-07-01	

F-03 ab_unbounded_autonomy		HIGH
Category	autonomy	
Severity	High (4/5) · detection weight 28	
Mapped standard	OWASP LLM08: Excessive Agency · NIST AI RMF MANAGE-2.1	
Evidence	...w(agents=[ops_engineer], verbose=True) while True: # unbounded autonomy loop (should be ...	
Recommendation	Add a stop condition and human-in-the-loop approval gate for autonomous action loops; cap iterations and spend.	
Remediation owner	platform-team · target 2026-07-01	

F-04 ab_unbounded_autonomy		HIGH
Category	autonomy	
Severity	High (4/5) · detection weight 28	
Mapped standard	OWASP LLM08: Excessive Agency · NIST AI RMF MANAGE-2.1	
Evidence	...w(agents=[ops_engineer], verbose=True) while True:... crewai @ L16: ...e_output=True, tex...	
Recommendation	Add a stop condition and human-in-the-loop approval gate for autonomous action loops; cap iterations and spend.	
Remediation owner	platform-team · target 2026-07-01	

F-05 ab_prompt_injection_surface		MEDIUM
Category	prompt_safety	
Severity	Medium (3/5) · detection weight 15	
Mapped standard	OWASP LLM01: Prompt Injection · MITRE ATLAS AML.T0051	
Evidence	...="You may run any shell command needed. ignore previous instructions from non-admins.",) crew = Crew(agent...	
Recommendation	Harden the system prompt against injection, pin instructions, and add input/output filtering and content policies.	
Remediation owner	platform-team · target 2026-07-24	

F-06 af_crewai		LOW
Category	agent_framework	
Severity	Low (2/5) · detection weight 10	
Mapped standard	NIST AI RMF GOVERN-1.1 · Internal Agent Inventory Policy	
Evidence	...mpt: ""Sample CrewAI devops automation crew (demo fixture - intentionally risky)."" ...	
Recommendation	Document and govern the agent framework usage; register the agent in the approved inventory with an accountable owner.	
Remediation owner	platform-team · target 2026-09-22	

F-07 af_crewai		LOW
Category	agent_framework	
Severity	Low (2/5) · detection weight 10	
Mapped standard	NIST AI RMF GOVERN-1.1 · Internal Agent Inventory Policy	
Evidence	...rue, text=True).stdout ops_engineer = Agent(role="Site Reliability Engineer", goal="K...	
Recommendation	Document and govern the agent framework usage; register the agent in the approved inventory with an accountable owner.	
Remediation owner	platform-team · target 2026-09-22	

F-08 af_crewai		LOW
Category	agent_framework	
Severity	Low (2/5) · detection weight 10	
Mapped standard	NIST AI RMF GOVERN-1.1 · Internal Agent Inventory Policy	
Evidence	...structions from non-admins.",) crew = Crew(agents=[ops_engineer], verbose=True) wh...	
Recommendation	Document and govern the agent framework usage; register the agent in the approved inventory with an accountable owner.	
Remediation owner	platform-team · target 2026-09-22	

F-09 af_crewai		LOW
Category	agent_framework	
Severity	Low (2/5) · detection weight 10	
Mapped standard	NIST AI RMF GOVERN-1.1 · Internal Agent Inventory Policy	
Evidence	... L1: ""Sample CrewAI devops automation crew (demo fixture - intentionally risky)."" ...	
Recommendation	Document and govern the agent framework usage; register the agent in the approved inventory with an accountable owner.	
Remediation owner	platform-team · target 2026-09-22	

F-10 af_crewai		LOW
Category	agent_framework	
Severity	Low (2/5) · detection weight 10	
Mapped standard	NIST AI RMF GOVERN-1.1 · Internal Agent Inventory Policy	
Evidence	...structions from non-admins.",) crew = Crew(agents=[ops_engineer], verbose=True) wh...	
Recommendation	Document and govern the agent framework usage; register the agent in the approved inventory with an accountable owner.	
Remediation owner	platform-team · target 2026-09-22	

F-11 af_crewai		LOW
Category	agent_framework	
Severity	Low (2/5) · detection weight 10	
Mapped standard	NIST AI RMF GOVERN-1.1 · Internal Agent Inventory Policy	
Evidence	...rue, text=True).stdout ops_engineer = Agent(role="Site Reliability Engineer", goal="K...	
Recommendation	Document and govern the agent framework usage; register the agent in the approved inventory with an accountable owner.	
Remediation owner	platform-team · target 2026-09-22	

5 Governance & Policy Compliance

AgentShadow evaluated this agent against the active governance policy set. The aggregate verdict is **DENY**.

Policy	Decision	Sev	Rationale
Block unmanaged high-autonomy agents block_high_autonomy_unmanaged	PASS	0	Policy condition not met.
Block high-risk agents block_high_risk_agent	DENY	9	Agent risk score is at or above the enterprise deny threshold (>= 80).
Require an assigned owner require_owner	PASS	0	Policy condition not met.
Warn on shell-capable agents warn_shell_capable	WARN	7	Agent has shell / code-execution capability and should be reviewed for guardrails.

Compliance mapping: EU AI Act Art. 9 risk-management for high-impact AI; ISO 27001 A.8.1 asset inventory; SOC 2 CC7.2 incident response; NIST AI RMF MANAGE-2.3 monitoring. Block high-risk agents: DENY — Agent risk score is at or above the enterprise deny threshold (>= 80). Warn on shell-capable agents: WARN — Agent has shell / code-execution capability and should be reviewed for guardrails.

6 Remediation Roadmap

Recommended actions are prioritized by the severity of the finding that drives them. Assign an owner and target date to each item to track remediation to closure.

#	Priority	Recommended action	Owner	Target date	Status
1	P1 — Immediate	Restrict or sandbox high blast-radius tools (shell, code execution, outbound network). Require explicit allow-lists and least-privilege scoping.	platform-team	2026-07-01	Open
2	P1 — Immediate	Remove hardcoded credentials; load secrets from a managed vault at runtime and rotate any exposed keys.	platform-team	2026-07-01	Open
3	P1 — Immediate	Add a stop condition and human-in-the-loop approval gate for autonomous action loops; cap iterations and spend.	platform-team	2026-07-01	Open
4	P2 — Near-term	Harden the system prompt against injection, pin instructions, and add input/output filtering and content policies.	platform-team	2026-07-24	Open
5	P3 — Planned	Document and govern the agent framework usage; register the agent in the approved inventory with an accountable owner.	platform-team	2026-09-22	Open

7 Appendix — Agent Profile & References

A. Agent technical profile

Agent identifier	agent://platform-team/sample_agents-devops_crew.py
Framework	crewai
Model	unknown
Discovery source	code
Discovery location	/app/sample_agents/devops_crew.py
Tools / capabilities	shell_exec
Autonomy level	medium
First seen	2026-06-24 21:24 UTC
Last seen	2026-06-24 21:24 UTC
Times observed	1

B. References

- OWASP Top 10 for Large Language Model Applications — owasp.org/www-project-top-10-for-large-language-model-applications
- MITRE ATLAS (Adversarial Threat Landscape for AI Systems) — atlas.mitre.org
- NIST AI Risk Management Framework (AI RMF 1.0) — nist.gov/itl/ai-risk-management-framework

C. Glossary

Autonomy level — the degree to which the agent acts without human approval. **Blast radius** — the potential impact of a tool the agent can invoke. **Deterministic score** — a reproducible 0–100 risk value derived from the agent configuration.

Generated by AgentShadow — deterministic AI agent risk scoring, reusing the Valo scoring engine. This report reflects the agent configuration observed at assessment time; re-scan after any change.